

【제 목】 : 수가시험사업 시스템 권한관리 미흡(시정)

【내 용】

- 의료수가실은 시험사업 대상 환자정보, 서비스 수행내역 등을 모니터링 하여 전산심사 연계 및 향후 시험사업 평가, 심사 시 청구시스템과 연계 등에 활용하기 위하여 내부관리시스템(이하 “시험사업 시스템” 이라 한다)을 구축·운영하고 있으며,
 - 시험사업 시스템에 대한 접근권한은 우리 원 권한관리시스템을 통해 관리하고 있고 시험사업 점검서식 조회 등 일부 화면에 대한 접근 권한은 의료수가실 전산담당자가 권한을 신청 받아 부여토록 하고 있다.
- 개인정보시스템에 대한 접근권한은 「개인정보 보호법」 제29조 및 동법 시행령 제30조, 「개인정보의 안전성 확보조치 기준」 제5조에 따라 업무 수행에 필요한 최소한의 범위로 차등 부여하여야 한다.

☞ 참고자료: 【개인정보 보호법】

제29조(안전조치의무)

개인정보처리자는 개인정보가 분실·도난·유출·변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 한다.

☞ **참고자료: 【개인정보 보호법 시행령】**

제30조(개인정보의 안전성 확보 조치)

- ① 개인정보처리자는 법 제29조에 따라 다음 각 호의 안전성 확보 조치를 하여야 한다.
- ② (생략)
- ③ 제1항에 따른 안전성 확보 조치에 관한 세부 기준은 보호위원회가 정하여 고시한다.

☞ **참고자료: 【(개인정보보호위원회) 개인정보의 안전성 확보조치 기준】**

제5조(접근 권한의 관리)

- ① 개인정보처리자는 개인정보처리시스템에 대한 접근권한을 업무수행에 필요한 최소한의 범위로 업무 담당자에 따라 차등 부여하여야 한다.
- ② ~ ⑦ (생략)

- 따라서 의료수가실은 시범사업 시스템의 접근권한을 업무 담당자에 따라 차등 부여하여 시스템에 보관 중인 개인정보가 보호될 수 있도록 관리를 철저히 하여야 한다.
- 이에 시범사업 시스템의 접근권한 관리 현황을 점검한 결과,
 - 시범사업 시스템의 접근권한은 **【그림 1】**와 같이 누구나 신청 가능한 ‘부서기본권한’으로 관리되고 있어 관리부서인 의료수가실의 승인절차 없이 신청자의 부서 내부 결재만으로 권한 신청·부여가 가능하였고,
 - **【그림 2】** 및 **【그림 3】**와 같이 일부 화면에서는 ‘수정’ 및 ‘제출취소’ 등 업무처리가 가능한 것으로 확인되었다.

【표 1】 접근권한 종류

구분	내용	신청 절차
부서 기본권한	모든 부서에 기본적으로 할당 되어 누구나 신청 가능한 권한	1. (신청부서) 사용자 권한 신청 → 내부분서 기안·결재 → 권한 부여완료 ※ 관리부서 승인 절차 필요 없음
업무권한	관리부서가 있는 권한으로서, 타 부서에서 사용 시 관리부서의 승인을 받은 후 사용 가능한 권한	1. (신청부서) 부서 권한 신청 → 내부분서 기안·결재 → 관리부서로 신청내역 전달 2. (관리부서) 부서 권한 신청 내역 확인 → 부서 권한 신청(승인) → 내부분서 기안·결재 3. (신청부서) 사용자 권한 신청 → 내부분서 기안·결재 → 권한 부여완료
사용자 기본권한	기본적으로 모든 사용자에게 부여되는 기본 권한	신청절차 없이 모든 사용자에게 기본적으로 부여됨

【그림 1】 시범사업 시스템 접근권한 내역

【그림 2】 시범사업 시스템의 접근·수정 가능 모습

【그림 3】 시범사업 시스템의 접근 · 제출취소 가능 모습

The screenshot shows the '평가시스템' (Evaluation System) interface. At the top, there are navigation tabs: '조사표자료구축', '사후관리', '평가행정N', and '중계'. Below these, there's a search bar and filters for '요양기관' (Nursing Institution) and '진찰일자' (Visit Date). The main table lists patients with columns for '순번' (Serial Number), '구분' (Category), '요양기관명' (Nursing Institution Name), '환자성명' (Patient Name), '생년월일' (Date of Birth), '성별' (Gender), 'HPI/N', '의사성명' (Physician Name), '진료과' (Department), '진료번호' (Medical Number), '면허번호' (License Number), '진찰일자' (Visit Date), and '시간' (Time). The '접근' (Access) button is highlighted with a red box, and the '제출취소' (Withdrawal) button is also highlighted with a red box.

○ 또한 일부 화면의 경우 전산팀에 별도로 권한신청 · 부여받아 접근이 되어야 함에도 【그림 4】와 같이 권한 신청 · 부여 없이도 화면 접근 및 수정이 가능한 것으로 확인되었다.

【그림 4】 시범사업 시스템의 접근 · 수정 가능 모습

The screenshot shows the '평가시스템' (Evaluation System) interface. At the top, there are navigation tabs: '조사표자료구축', '사후관리', '평가행정N', and '중계'. Below these, there's a search bar and filters for '요양기관' (Nursing Institution) and '진찰일자' (Visit Date). The main table lists patients with columns for '연번' (Serial Number), '요양기관명' (Nursing Institution Name), '수진자 일련번호' (Patient Serial Number), '환자성명' (Patient Name), '생년월일' (Date of Birth), '성별' (Gender), 'HPI/N', '주상명' (Main Name), '입원일자' (Admission Date), '서식구분' (Form Category), '수거코드' (Collection Code), '시행일자' (Implementation Date), '관리일자' (Management Date), '제출일자' (Submission Date), '제출상태' (Submission Status), and '작성방법' (Writing Method). The '제출상태' (Submission Status) column is highlighted with a red box.

○ 그 결과 시범사업으로 수집된 환자의 성명, 생년월일, 상병명 등의 개인정보가 보호되지 못할 우려가 있다.

【관계부서 의견】

- 접근권한의 관리 미흡으로 인해 개인정보가 보호 되지 못할 우려에 대해 공감하였고, 접근권한을 업무 담당자에 따라 차등 부여하는 등 시스템 권한관리 방법을 개선하겠다는 의견을 제시하였다.

【조치할 사항】

- 개발상임이사는 시범사업 시스템의 접근권한이 업무 담당자에 따라 차등부여 될 수 있도록 권한을 구분하여 관리·운영하시고, 앞으로 개인정보가 철저히 보호될 수 있도록 관련 업무 수행에 만전을 기하시기 바랍니다. (시정)